

Security Waiver: SigNoz Docker Image Vulnerabilities (2025-10-07)

Overview

During the Docker Scout scan of the `signoz/signoz:v0.96.1` container image we identified multiple OpenSSL vulnerabilities. The scan returned **0 critical, 2 high, 7 medium** and **3 low** findings. All of the high and medium vulnerabilities are due to the **OpenSSL 3.3.2-r0** package baked into the upstream SigNoz image. Fixed versions (e.g. 3.3.5-r0 and 3.3.3-r0) are available, but these must be published by the SigNoz project before we can upgrade.

Risk Assessment

1. **Zero critical CVEs** – no critical vulnerabilities were detected in the scanned image.
2. **Upstream dependencies** – the affected components are part of the base SigNoz image and are not introduced by our code.
3. **Low exploitation probability** – EPSS scores for the identified CVEs range from **0.017 %** to **0.652 %**, indicating a very low chance of active exploitation in the wild.
4. **Local-only deployment** – SigNoz is deployed on **localhost** for observability purposes and is not exposed to external networks.
5. **Not immediately fixable** – patching these vulnerabilities requires the SigNoz team to release a new image; we will upgrade as soon as a patched version (v0.96.2 or later) becomes available.

Decision and Rationale

After weighing the above factors and in accordance with Bosscat OEM governance, we are issuing a **security waiver** for the OpenSSL vulnerabilities in the SigNoz image. This waiver allows us to proceed with deployment and documentation while clearly acknowledging and tracking the risk. The vulnerabilities are low risk in our context (local-only, low EPSS) and do not warrant blocking valuable documentation work. We commit to upgrading to a fixed image as soon as SigNoz releases one.

Conditions and Caveats

- **Track upstream releases:** monitor SigNoz updates and upgrade to v0.96.2+ when available.
- **Document the waiver:** mark the current security test as “waived” in the test results and include this document in the ECRR reports.
- **Network isolation:** ensure that the SigNoz instance remains accessible only from localhost.
- **Review date:** revisit this waiver on or before **2025-11-07** to determine if a patched image is available or if the risk profile has changed.

Approval

- **Approved by:** Bosscat OEM
 - **Date of approval:** 2025-10-07
 - **Review date:** 2025-11-07
-